

Plan de Implementación: Monolito Modular Endurecido

Proyecto: ServidorInventario (Centro Judicial San Pedro, Jujuy)

Fecha: Agosto 2026

Estado: Propuesta Formal de Arquitectura y Seguridad

1. Objetivo General

Evolucionar la arquitectura actual de la aplicación de un monolito directo en Flask hacia un **Monolito Modular Endurecido**, asegurando la mantenibilidad, escalabilidad, trazabilidad y seguridad sin alterar la pila tecnológica central (**Python 3.13 / Flask / Jinja2 / MySQL**).

[!IMPORTANT]

Principio de Continuidad Institucional: No se reemplazará Flask, Jinja2, MySQL ni la integración con Active Directory. Todas las refactorizaciones y endurecimientos deben preservar la lógica de negocio activa en producción en el Poder Judicial.

2. Principios de Diseño

1. Separación de Responsabilidades en Capas:

- **blueprints/**: Rutas HTTP y manejo de solicitudes/respuestas Jinja/JSON.
- **services/**: Lógica de negocio orquestada.
- **repositories/**: Consultas SQL parametrizadas y abstracción de persistencia.
- **validators/ / utils/**: Validación de entradas de usuario y desinfección.

2. Endurecimiento Proactivo de Seguridad (Security-by-Design):

- Cero secretos en código fuente.
- SQL 100% parametrizado.
- Escape y sanitización de filtros LDAP.
- Protección CSRF en todas las operaciones mutativas (**POST/PUT/DELETE**).

3. Evolución Gradual e Incremental:

- Cambios en Merge Requests (MRs) pequeños y atómicos.
- Cobertura de pruebas automáticas para cada módulo modificado.

3. Fase 1: Seguridad Urgente y Endurecimiento Inicial

Tarea 1.1: Depuración y Rotación de Secretos

- **Acción:** Eliminar cualquier token de Green-API, credenciales de MySQL o llaves API codificadas directamente en archivos Python.
- **Implementación:** Cargar únicamente vía variables de entorno (**.env**). Mantener **.env.example** sincronizado con valores ficticios.

Tarea 1.2: Remoción de Fallbacks Hardcodeados en Ingesta

- **Acción:** Quitar credenciales o comportamientos por defecto inseguros en la ruta **/submit_inventory** (ingesta de telemetría de PCs).

- **Implementación:** Retornar errores explícitos (401/403) cuando falte el token o header de autenticación de script cliente.

Tarea 1.3: Sanitización y Escape de Filtros LDAP (Active Directory)

- **Acción:** Prevenir inyecciones LDAP en `services/ad_service.py` o módulos afines.
- **Implementación:** Escapar caracteres reservados de filtros LDAP (`*`, `(`, `)`, `\`, `\0`) en entradas de usuario como nombre de usuario o búsqueda de personal.

Tarea 1.4: Protección de Vault (Llavero / Secretos)

- **Acción:** Convertir la acción de eliminación en `blueprints/bp_vault.py` de `GET` a `POST` con token CSRF.
- **Acción:** Reemplazar listas hardcodedas de usuarios administradores en Vault por verificación basada en roles y permisos en base de datos.

4. Fases Posteriores: Modularización y Calidad

Fase 2: Autenticación, Tokens y Scopes

- Gestión de sesiones robustas con expiración.
- Asignación de tokens con ámbitos de permisos explícitos (`*scopes*`) para scripts de telemetría y APIs externas (e.g., API Contable).

Fase 3: Migraciones Versionadas y Capa de Repositorios

- Introducción de herramientas de migración versionada para MySQL (Alembic o scripts SQL indexados).
- Creación de la capa `repositories/` para desacoplar las consultas directas `pymysql` / `cursor` de los endpoints Flask.

Fase 4: Observabilidad, Auditoría y Backups

- Registro centralizado de eventos auditables (`*audit log*`) en base de datos para acciones críticas (Vault, bajas de patrimonio, cambios de usuario).
- Script de backups automatizados con verificación de integridad.

5. Instrucciones para Agentes IA e Implementadores

1. **Lectura obligatoria:** Consultar siempre `AGENTS.md` y `CONTEXT.md` antes de realizar cambios.
2. **Entorno de Producción:** NUNCA ejecutar comandos destructivos en la base de datos remota sin confirmación explícita.
3. **Dependencias:** No agregar paquetes innecesarios al proyecto. Utilizar las herramientas existentes en `requirements.txt`.
4. **Verificación:** Cada cambio debe incluir pruebas de humo o tests unitarios demostrables.